

Universidad Politécnica de San Luis Potosí

**ACTIVIDAD 01: Análisis en grupo de un ciberataque real
y su impacto empresarial.**

A.P. Møller–Maersk - Ataque NotPetya (2017)

Presentado por:

Christian Alfredo Morales Meza - 184937

Asignatura: CNO IV Seguridad Informática

Profesor: Servando López Contreras

Fecha de entrega: 24/08/2026

Índice de contenido

Índice de contenido	2
Introducción	2
Informe	3
Línea del tiempo del ataque.....	3
Contexto general del ataque	4
Tabla técnica del ataque.	4
Evaluación del impacto (Modelo CIA)	6
Cálculo del costo total del ciberataque.....	6
Relación con marcos normativos.	7
Lecciones aprendidas y recomendaciones.....	8
Conclusiones	9
Bibliografía.....	10

Introducción

El presente informe analiza el caso del ataque NotPetya ocurrido en junio de 2017 contra la naviera danesa A.P. Møller–Maersk, considerado uno de los ciberataques más costosos de la historia. A partir de fuentes técnicas verificables, se examinan las causas, el desarrollo, el impacto sobre los principios de confidencialidad, integridad y disponibilidad (CIA), el costo económico estimado en pesos mexicanos, su relación con marcos normativos internacionales y las lecciones que pueden aplicarse al contexto mexicano y latinoamericano.

Informe

Línea del tiempo del ataque

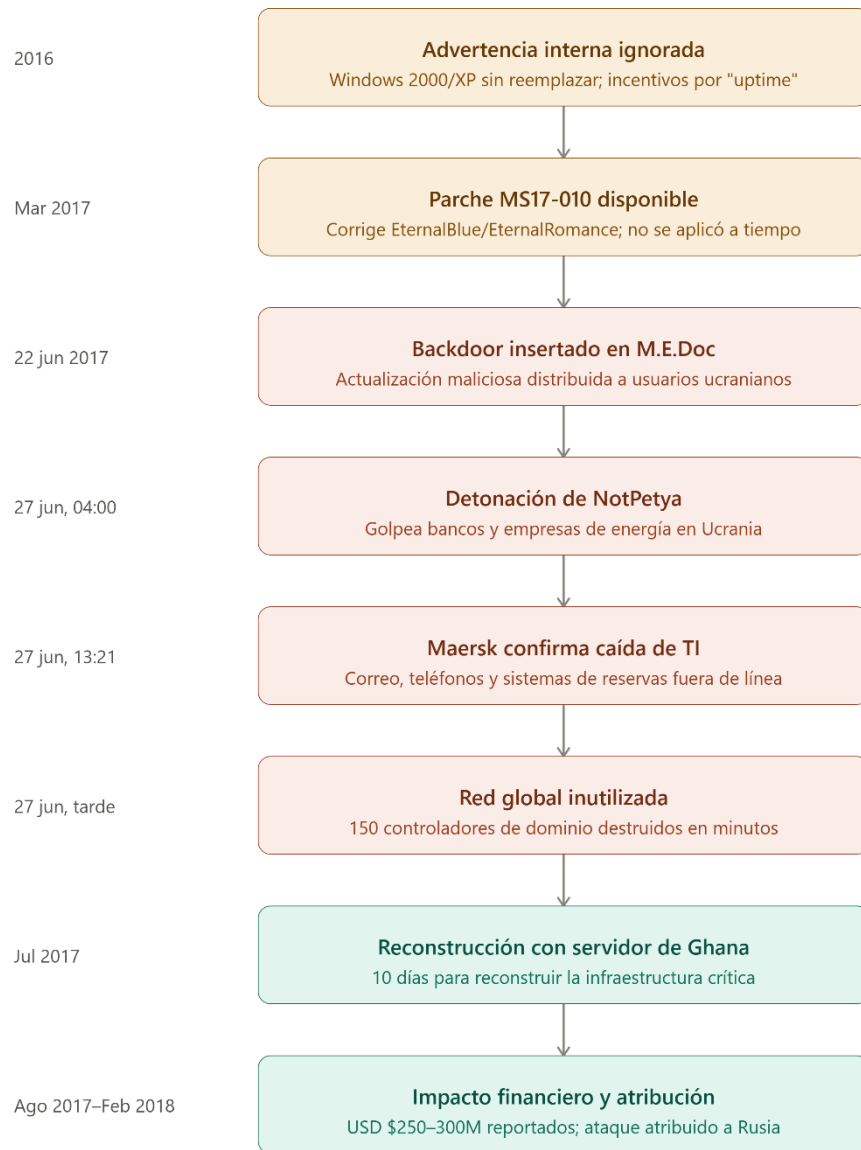


Figura 1. Línea del tiempo. Análisis del ataque

Contexto general del ataque

Año y país de origen: El ataque se detectó el 27 de junio de 2017, con foco inicial en Ucrania, aunque se propagó en cuestión de horas a más de 65 países [4].

Empresa afectada: A.P. Møller–Maersk, con sede en Copenhague, Dinamarca, la mayor naviera de contenedores del mundo, responsable en ese momento de aproximadamente una quinta parte del comercio marítimo global, con 76 terminales portuarias, cerca de 800 buques y presencia en 130 países [7].

Condiciones de ciberseguridad previas: De acuerdo con declaraciones del propio presidente de Maersk, Jim Hagemann Snabe, la compañía contaba con una postura de ciberseguridad "básicamente promedio", comparable a la de muchas otras empresas de su tamaño [3]. La infraestructura incluía sistemas heredados (Windows 2000 y Windows XP) pendientes de actualización, y administradores de sistemas habían advertido desde 2016 sobre la vulnerabilidad de una red de más de 80,000 equipos, sin que la modernización se completara a tiempo [1].

Factores que facilitaron el ataque: Confluyeron fallas técnicas y humanas. En marzo de 2017, Microsoft había publicado el parche MS17-010 para la vulnerabilidad EternalBlue en el protocolo SMB, pero no todos los sistemas de Maersk estaban actualizados [2]; además, un administrador de dominio había iniciado sesión en un servidor pocos días antes del ataque, dejando credenciales privilegiadas expuestas en memoria [2].

Tabla técnica del ataque.

Elemento	Descripción
Tipo de ataque	Malware destructivo ("wiper") disfrazado de ransomware; se presentó como una variante de Petya, por lo que se le denominó NotPetya / EternalPetya.
Actor o grupo atacante	Sandworm Team, unidad vinculada a la inteligencia militar rusa (GRU). Atribución sostenida por los gobiernos de EE. UU., Reino Unido y Ucrania.

Vector de entrada	Actualización comprometida del software de contabilidad y facturación ucraniano M.E.Doc (Intellect Service), de uso obligatorio para empresas que operan en Ucrania.
Vulnerabilidad explotada	CVE-2017-0144 (EternalBlue) y CVE-2017-0145 (EternalRomance) sobre el protocolo SMBv1, corregidas por Microsoft en el boletín MS17-010 (marzo 2017) pero no aplicadas en Maersk; adicionalmente, reutilización de credenciales de administrador de dominio.
Etapas del ataque (MITRE ATT&CK)	Acceso inicial: T1195.002 (compromiso de cadena de suministro de software). Ejecución: T1204/T1059 (actualización maliciosa autoejecutada, 27 jun. 2017). Acceso a credenciales: T1003.001 (volcado de credenciales tipo Mimikatz desde LSASS). Movimiento lateral: T1210 (explotación de servicios remotos vía EternalBlue/EternalRomance) y T1021.002 (SMB/recursos administrativos, PsExec/WMIC). Impacto: T1485 (destrucción de datos) y T1561 (borrado de disco: sobrescritura de MBR y MFT).
Sistemas o servicios comprometidos	Aproximadamente 150 controladores de dominio (Active Directory) sincronizados, entre 45,000 y 49,000 estaciones de trabajo, cerca de 4,000 servidores y 2,500 aplicaciones; sistemas de las terminales portuarias operadas por APM Terminals en 76 puertos de 59 países; correo electrónico, telefonía IP, sistemas de reservas, facturación y atención a clientes.
Duración del incidente	Propagación e interrupción total de la red: minutos a horas, el mismo 27 de junio de 2017. Reconstrucción de la infraestructura crítica (reinstalación de servidores y equipos): aproximadamente 10 días. Normalización operativa completa de reservas, facturación y capacidad portuaria: varias semanas adicionales.
Mecanismos de detección y respuesta	No existía un mecanismo de detección temprana capaz de contener la propagación; el malware evadió antivirus tradicionales al usar herramientas legítimas del sistema. La respuesta inicial fue manual: desconexión física de equipos y centros de datos por parte del personal de TI. La recuperación fue posible gracias a un controlador de dominio en la oficina de Ghana que permaneció desconectado por un corte de energía previo al ataque, preservando una copia íntegra de Active Directory; participaron equipos de emergencia de Microsoft y de la consultora Deloitte.

Evaluación del impacto (Modelo CIA)

Principio	Nivel de impacto	Evidencia del caso
Confidencialidad	Impacto limitado.	Según declaraciones del propio CEO Søren Skou, no se identificó robo ni fuga confirmada de datos de clientes; el objetivo del malware era destructivo, no exfiltrar información [5]. Aun así, el compromiso de credenciales de administrador de dominio implicó una exposición potencial de información sensible de la red interna [2].
Integridad	Impacto crítico.	NotPetya sobrescribió el Registro de Arranque Maestro (MBR) y cifró la Tabla Maestra de Archivos (MFT) de forma irreversible —sin posibilidad real de recuperación, aunque se pagara el rescate— [4], destruyendo tanto la copia primaria como la de respaldo de Active Directory en la mayoría de las ubicaciones de Maersk [2] [1].
Disponibilidad	Impacto extremo.	Caída total de los sistemas de TI a nivel global: correo electrónico, telefonía, sitio de reservas en línea, sistemas de facturación y control de contenedores quedaron inoperables [5]. Entre 17 y 76 terminales portuarias suspendieron o redujeron drásticamente sus operaciones [7]; la empresa recurrió a procesos manuales durante 10 días [3] y registró una caída de hasta el 20% en volúmenes de negocio durante varias semanas [3].

Cálculo del costo total del ciberataque

Maersk reportó públicamente, a través de su presidente Jim Hagemann Snabe en el Foro Económico Mundial de Davos [3], y en su informe financiero del segundo trimestre de 2017 [6], un impacto económico total de entre USD 200 y 300 millones, con una estimación central de USD 250-300 millones [1] [6]. Para efectos de este análisis se utiliza un punto medio de USD 275 millones, convertido a pesos mexicanos con el tipo de cambio promedio de referencia para 2017 (aproximadamente \$18.90 MXN por dólar, consistente con los indicadores históricos publicados por el Banco de México) [8].

Tipo de costo	Descripción	Estimación (USD)	Estimación (MXN)
Pérdidas operativas	Interrupción de reservas, facturación y operación en 17-76 terminales durante ~10-14 días; caída de hasta 20% en volúmenes de negocio durante varias semanas [3] [7].	≈ USD 150,000,000	≈ \$ 2,835,000,000 MXN
Costos técnicos	Reinstalación completa de infraestructura: 4,000 servidores, 45,000 PC y 2,500 aplicaciones en 10 días; horas extraordinarias de personal de TI y proveedores externos [3].	≈ USD 90,000,000	≈ \$ 1,701,000,000 MXN
Daños reputacionales	Percepción de riesgo entre clientes, cobertura mediática global negativa, revisión de contratos por parte de aseguradoras y socios comerciales [1].	≈ USD 25,000,000	≈ \$ 472,500,000 MXN
Costos legales / regulatorios	Revisión contractual con clientes y aseguradoras; no se registraron multas regulatorias formales por tratarse de un incidente sin fuga confirmada de datos personales [5].	≈ USD 10,000,000	≈ \$ 189,000,000 MXN
Pago de rescate o extorsión	No se realizó pago efectivo: la dirección de correo del atacante fue bloqueada por el proveedor Posteo el mismo día del ataque [4]; el rescate solicitado era de USD 300 por equipo, monto irrelevante frente al daño total [4].	USD 0 (no pagado)	\$ 0 MXN
TOTAL ESTIMADO	Suma de pérdidas directas e indirectas reportadas públicamente por la compañía [1] [6].	≈ USD 275,000,000	≈ \$ 5,197,500,000 MXN

Relación con marcos normativos.

Control / marco de referencia	Cómo habría prevenido o mitigado el impacto
ISO/IEC 27001 — A.8.8 (Gestión de vulnerabilidades técnicas)	Un programa formal de gestión de parches habría asegurado que todos los sistemas Windows aplicaran

	MS17-010 antes de junio de 2017, cerrando la vía de explotación de EternalBlue [2] [4].
ISO/IEC 27001 — A.5.19-5.23 (Seguridad en las relaciones con proveedores)	La evaluación y monitoreo continuo de proveedores críticos de software, como M.E.Doc, habría permitido detectar la falta de actualizaciones y controles en sus servidores antes de que se convirtiera en vector de ataque [4].
ISO/IEC 27001 — A.8.22 (Segregación de redes)	La segmentación de red y la separación de controladores de dominio habrían limitado la propagación lateral del malware y evitado la pérdida simultánea de las copias primaria y de respaldo de Active Directory [2].
NIST CSF — función Protect (PR.AC, gestión de identidades y control de acceso con privilegio mínimo)	Restringir y monitorear las credenciales de administrador de dominio habría reducido la capacidad de Mimikatz para escalar privilegios y moverse lateralmente [2] [1].
NIST CSF — función Recover (RC.RP, planificación de recuperación)	Contar con copias de respaldo aisladas (offline) de Active Directory en múltiples ubicaciones —y no depender de un servidor que por azar permaneció desconectado— habría acelerado drásticamente la recuperación [1] [2].
NIST CSF — función Identify (ID.SC, gestión de riesgos de la cadena de suministro)	Un mapeo de dependencias críticas de software de terceros habría anticipado el riesgo sistémico que representaba una herramienta de uso obligatorio como M.E.Doc [4].

Lecciones aprendidas y recomendaciones

Fallas críticas detectadas

- Gestión de parches inconsistente: el parche para EternalBlue existía desde marzo de 2017, pero no se había desplegado en toda la infraestructura al momento del ataque en junio [2].
- Dependencia excesiva de un único software de terceros de uso obligatorio (M.E.Doc), sin controles adicionales de aislamiento o monitoreo sobre su canal de actualización [4].

- Ausencia de segmentación efectiva de red, que permitió que credenciales de administrador de dominio comprometidas se usaran para infectar decenas de miles de dispositivos en minutos [2].
- Estrategia de respaldo no resiliente: tanto la copia primaria como la de contingencia de Active Directory quedaron inutilizables, y la recuperación dependió de una casualidad (un servidor fuera de línea por un corte eléctrico) [1] [2].
- Percepción organizacional de la ciberseguridad como función netamente técnica, no como prioridad estratégica del negocio, antes del incidente [3].

Buenas prácticas y recomendaciones aplicables al contexto mexicano y latinoamericano

- Implementar un programa formal y auditable de gestión de parches y actualizaciones críticas, con plazos máximos de aplicación para vulnerabilidades de severidad alta.
- Evaluar el riesgo de terceros y proveedores de software crítico —particularmente relevante en México, donde el uso de plataformas de facturación electrónica y proveedores autorizados por el SAT genera dependencias similares a la de M.E.Doc en Ucrania.
- Elevar la ciberseguridad a nivel de gobierno corporativo, con reportes regulares al consejo de administración y presupuesto proporcional al riesgo, no solo al gasto histórico de TI.
- Contratar cobertura de ciberseguros y desarrollar planes de continuidad de negocio (BCP) y de comunicación de crisis, siguiendo el ejemplo de la comunicación transparente que Maersk mantuvo durante el incidente [7] [5].

Conclusiones

El caso de Maersk demuestra que un ciberataque no dirigido específicamente contra una organización puede, aun así, generar pérdidas económicas comparables a las de un desastre operativo mayor: entre USD 250 y 300 millones (aproximadamente \$5,200 millones de pesos mexicanos) [1] [6], la reconstrucción completa de la infraestructura de TI en tan solo diez días [3], y la interrupción de servicios logísticos críticos para el comercio internacional [7].

Asimismo, evidencia el riesgo sistémico que representan las cadenas de suministro digitales, en las que la seguridad de un proveedor de software de terceros puede convertirse en la puerta de entrada para comprometer a corporaciones multinacionales.

Bibliografía

- [1] Greenberg, A. (2018). "The Untold Story of NotPetya, the Most Devastating Cyberattack in History" y el libro Sandworm: A New Era of Cyberwar and the Hunt for the Kremlin's Most Dangerous Hackers. Referencia técnica sobre la atribución del ataque al grupo Sandworm (GRU) y el costo estimado por Maersk (USD 250-300 millones).
- [2] CSO Online (2019). "Rebuilding after NotPetya: How Maersk moved forward", basado en la presentación de Adam Banks (CTO/CIO de Maersk) y Andy Powell (CISO) en el Gartner Risk Summit de Londres. Disponible en: <https://www.csoonline.com/article/567845/rebuilding-after-notpetya-how-maersk-moved-forward.html>
- [3] Bleeping Computer (2018). "Maersk Reinstalled 45,000 PCs and 4,000 Servers to Recover From NotPetya Attack", con declaraciones de Jim Hagemann Snabe en el Foro Económico Mundial de Davos. Disponible en: <https://www.bleepingcomputer.com/news/security/maersk-reinstalled-45-000-pcs-and-4-000-servers-to-recover-from-notpetya-attack/>
- [4] Tripwire — The State of Security (2017). "NotPetya: Timeline of a Ransomware", cronología técnica de la propagación, atribución de Kaspersky Lab y uso del exploit EternalBlue. Disponible en: <https://www.tripwire.com/state-of-security/notpetya-timeline-of-a-ransomware>
- [5] The Register (2017). "NotPetya ransomware attack cost us \$300m – shipping giant Maersk", con declaraciones del CEO Søren Skou sobre la ausencia de fuga de datos confirmada. Disponible en: https://www.theregister.com/2017/08/16/notpetya_ransomware_attack_cost_us_300m_says_shipping_giant_maersk/
- [6] CBC News (2017). "Petya ransomware cost world's biggest container ship company up to \$300M", con cifras del reporte financiero del segundo trimestre de 2017 de A.P. Møller–Maersk. Disponible en: <https://www.cbc.ca/1.4249283>

- [7] SAFETY4SEA (2018). "Maersk Line: Surviving from a cyber attack", análisis del sector marítimo sobre el incidente y su relación con la Resolución MSC.428(98) de la OMI sobre gestión de riesgos cibernéticos marítimos. Disponible en: <https://safety4sea.com/cm-maersk-line-surviving-from-a-cyber-attack/>
- [8] Banco de México (Banxico). Sistema de Información Económica (SIE) — Tipo de cambio peso-dólar. Utilizado como referencia para la conversión de cifras a pesos mexicanos. Disponible en: <https://www.banxico.org.mx/SieInternet/>